

2019 경기도기능경기대회 채점기준(2과제)

1. 채점시 유의사항	직 종 명	사이버 보안
1. 모든 호스트를 재시작 후 채점을 시작하며, 각종 서비스 및 호스트의 재시작은 총 3회 이내로 제한합니다. - 단, IP를 자동으로 받아오는 클라이언트의 경우 IP를 다시 받아오는 작업은 서비스 재시작 총 횟수와 무관합니다. 2. 대소문자를 구분합니다. 3. 로그인할 사용자가 명시되어 있지 않은 경우, 아래의 사용자로 로그인합니다. - Windows OS -> user, Windows Server = kgAdmin - Linux OS -> secu2019 4. 부분 점수가 인정되는 항목은 별도로 표시되어 있습니다. 5. 채점 시 주어지지 않은 모든 암호는 "cyberP@ss12# \$"를 사용합니다.		

2. 채점 기준표

가. 배 점(경기종료 후 채점)

번호	제목	배점 번호	배점 항목	배점	비고
1	리눅스 시스템 보안	1-1)	히스토리 형태 변경	2	
		1-2)	최근 명령어 갯수	1	
		1-3)	root 로그인 제한 및 로그	2	부분점수
		1-4)	세션시간	1	
		1-5)	계정 정책(암호, 잠김, su, 로그)	4	부분점수
2	윈도 시스템 보안	2-1)	Administrator 변경	1	
		2-2)	폴더 공유 제거	2	
		2-3)	RDP	3	
		2-4)	로그인/ 아웃 로그	2	
		2-5)	암호정책	1	
		2-6)	계정 잠김	1	
		2-7)	폴더 리디렉션	2	
3	응용프로그램보안	3-1)	ssh 인증키 위치	2	
		3-2)	putty 설정, 서버 접속(ns1, www)	4	
		3-3)	웹서비스인증	2	부분점수
		3-4)	로그	2	
4	네트워크 보안	4-1)	AAA 인증	4	부분점수
		4-2)	네트워크 제한	1	
		4-3)	UTM 설정	3	부분점수
5	취약점 분석 및 대응	5-1)	IP 검색	1	
		5-2)	취약점 분석 보고서	3	
		5-3)	root 암호 탈취 및 변경	3	
		5-4)	서비스 취약점 해결	3	
합계				50	

나. 채점방법 및 기준 (경기종료 후 채점)

번호	세부 채점 내용
1	※ 주의 사항 채점 전에 호스트 및 게스트가 전원이 off 되어 있어야 하며, 채점 대기 시 호스트 전원을 켜다. 게스트 OS의 경우 채점 시작 시 심사위원 앞에서 전원을 ON 해야 한다. ●리눅스 시스템 보안 채점 1) 히스토리 형태 변경[2점] - 아래 그림과 같이 “번호 날짜 명령어” 순으로 출력되는지 확인한다. - ns1 서버에 secu2019 로 로그인 <pre>[secu2019@ns1 ~]\$ history head -n 3 1 2019-03-03_02:42:59 sudo shutdown 2 2019-03-03_02:42:59 sudo poweroff 3 2019-03-03_02:42:59 ifconfig</pre> 번호, 날짜, 명령어의 값은 다를 수 있음. \$ su - 명령어로 root 로 변경하여 아래와 같은 지 확인한다. <pre>[root@ns1 ~]# history head -n 3 1 2019-03-03_02:44:25 mkdir /media/ 2 2019-03-03_02:44:25 mount /dev/sr 3 2019-03-03_02:44:25 cd /etc/</pre> 번호, 날짜, 명령어의 값은 다를 수 있음. - www, CB-L-01 에서도 같은 결과인지 확인한다. 2) 히스토리 형태 변경[2점] - ns1 에 로그인 , 다음과 같은지 확인한다. (로그인 계정은 secu2019, kgAdmin, webAdmin 중 심사위원이 결정한 사용자로 한다) <pre>[secu2019@ns1 ~]\$ history wc -l 20</pre> www, CB-L-01 에서도 위와 같이 진행한다. 3) root 제한 및 로그 [2점], 부분점수 - ns1 서버의 tty1 에 root로 로그인 시도 / 접속이 제한되어야 한다. <pre>ns1 login: root Password: Login incorrect</pre> - secu2019로 로그인 후 다음과 같이 root 로 사용자 변경이 성공되어야 한다. <pre>[secu2019@ns1 ~]\$ su - Password: Last login: Sun Mar 3 03:15:40 [root@ns1 ~]#</pre> - www 서버에서도 위와 같은 지 확인한다. ==> 1점

<이어서 채점>

- 아래와 같이 root 명령어 로그를 확인한다.
- 입력했던 3개의 명령어가 cmd.log 파일에 하단에 있는지 확인한다.

```
[root@ns1 ~]# echo "" > /var/log/cmd.log
[root@ns1 ~]# w
 03:21:23 up 2 days, 6:28, 2 users, load average: 0.01, 0.02, 0.05
USER      TTY      FROM          LOGIN@   IDLE   JCPU   PCPU   WHAT
secu2019  tty1                    02:42    3.00s  0.72s  0.10s  login -- secu2019
kgAdmin   pts/0    172.30.10.101 01:36    1:44m  0.07s  0.07s  -bash
[root@ns1 ~]# cat /var/log/cmd.log

Mar  3 03:21:21 ns1 secu2019: [1] PID=17632, PWD=/root, TTY=/dev/tty1, CMD= 14 2019-03-03_03:21:2
1 echo "" > /var/log/cmd.log
Mar  3 03:21:23 ns1 secu2019: [2] STAT=0
Mar  3 03:21:23 ns1 secu2019: [1] PID=17632, PWD=/root, TTY=/dev/tty1, CMD= 15 2019-03-03_03:21:2
3 w
Mar  3 03:21:25 ns1 secu2019: [2] STAT=0
Mar  3 03:21:25 ns1 secu2019: [1] PID=17632, PWD=/root, TTY=/dev/tty1, CMD= 16 2019-03-03_03:21:2
5 cat /var/log/cmd.log
[root@ns1 ~]#
```

- www 서버에서도 진행한다. --> 1점

4) 세션시간[1점]

- 기존 tty1을 모두 로그아웃 한다.
- ns1 서버의 tty1에서 secu2019 로 로그인한다. 1분후 로그아웃 되는지 확인한다.
- www 서버의 tty1에서 kgAdmin 으로 로그인한다. 1분후 로그아웃 되는지 확인한다.

5) 계정 정책[4점, 부분점수]

5)-1. 계정 잠김[1점]

ns1 에 tty1에 secu2019 로 로그인 / 암호 12345

- 3회 실패해야 한다.
- 4번째 로그인 시도 시 아래와 같은 메시지가 보여야 한다.

```
ns1 login: secu2019
Account locked due to 4 failed logins
Password:
Login incorrect
```

정상암호 입력 : cyberP@ss12#\$

<30초 이상 대기한다.>

아래와 같이 정상적으로 로그인 되면서, 실패 횟수가 보여야 한다.

```
ns1 login: secu2019
Password:
Last failed login: Tue Mar  5 08:41:00 EST 2019 on tty2
There were 4 failed login attempts since the last successful login.
Last login: Mon Mar  4 20:07:35 on tty1
[secu2019@ns1 ~]$
```

다음 채점을 위해 su - 를 입력하여 root로 로그인한다.

5)-2. 계정 암호 정책[1점]

```
#adduser test
```

```
#passwd test
```

<Secu12#\$ 으로 암호 생성>

tty3으로 이동

test 로 로그인

```
ns1 login: test
Password:
```

암호변경 시도 -> 암호 Secu12#\$ 입력 -> 다음과 같은 메시지가 보여야 함.

```
[test@ns1 ~]$ passwd
Changing password for user test.
Changing password for test.
(current) UNIX password:
You must wait longer to change your password
```

tty1 에서 현재시간을 확인하고

```
[root@ns1 ~]# date
Tue Mar 5 00:52:36 EST 2019
```

현재 시간보다 1일 1분을 더하여 설정한다.

```
[root@ns1 ~]# date -s '2019-3-6 00:53:00'
Wed Mar 6 00:53:00 EST 2019
```

tty3 에서 다음과 같이 test 계정의 암호 변경을 시도 합니다.

```
[test@ns1 ~]$ passwd
Changing password for user test.
Changing password for test.
(current) UNIX password:
new password: _
```

현재 암호를 입력하면 암호변경이 가능해야 한다.

다음 암호로 변경을 시도한 후 메시지를 확인합니다.

123 = The password contains less than 1 uppercase letters

cyberP@ss = The password contains less than 1 digits

cyberP2ss = The password contains less than 1 non-alphanumeric characters

Secu12#\$ = The password is the same as the old one

P@ss12#\$ = The password is too similar to the old one

CyberP@ss12#\$ => 변경완료

다음과 같이 계정 만료 정책을 확인합니다.

```
[test@ns1 ~]$ chage -l test | tail -n 3
Minimum number of days between password change      : 1
Maximum number of days between password change      : 90
Number of days of warning before password expires   : 30
```

5)-3. su 사용[1점]

- ns1에서 tty2에 secu2019 로 로그인/
\$ su - --> root로 로그인이 되어야 한다.

tty3에서 kgAdmin 으로 로그인

\$ su - --> root로 로그인이 되어야 한다.

tty4에서 testuser 으로 로그인

```
[testuser@ns1 ~]$ su -
Password:
su: Permission denied
```

5)-4. tty3 에서 로그 확인[1점]

#tail /var/log/sulog

```
Mar 4 07:20:06 ns1 login: pam_unix(login:session): session opened for user secu2019 by LOGIN(uid=0)
Mar 4 07:20:06 ns1 login: LOGIN ON tty5 BY secu2019
Mar 4 07:20:11 ns1 su: pam_unix(su-l:session): session opened for user root by secu2019(uid=1000)
Mar 4 07:20:20 ns1 login: pam_unix(login:session): session opened for user kgAdmin by LOGIN(uid=0)
Mar 4 07:20:20 ns1 login: LOGIN ON tty3 BY kgAdmin
Mar 4 07:20:25 ns1 su: pam_unix(su-l:session): session opened for user root by kgAdmin(uid=1001)
Mar 4 07:20:37 ns1 login: pam_unix(login:session): session opened for user testuser by LOGIN(uid=0)
Mar 4 07:20:37 ns1 login: LOGIN ON tty4 BY testuser
Mar 4 07:20:44 ns1 su: pam_succeed_if(su-l:auth): requirement "uid >= 1000" not met by user "root"
```

● 윈도우 서버 보안

1) Administrator , Guest 변경[1점]

- DC 서버에 kgAdmin2019 로 로그인 (암호 cyberP@ss12#\$)
- cmd에서 아래와 같이 실행

```
C:\Users\kgAdmin2019>net user kgAdmin2019
사용자 이름 kgAdmin2019
전체 이름
설명 컴퓨터 도메인을 관리하도록 기본 제공된 계정
사용자 설명
<생략>
로컬 그룹 구성원 *Administrators
```

2 C:\Users\kgAdmin2019>net user Guest

```
사용자 이름 Guest
전체 이름
설명 게스트가 컴퓨터 도메인을
국가/지역 코드 000 (시스템 기본값)
활성 계정 아니요
```

2) 기본 폴더 제거 [2점]

▲ DC 에 KG\kgAdmin2019 로 로그인 -> cmd -> net share -> 공유 이름에 C\$, D\$ 등 하드디스크가 보이지 않아야 한다.

▲ CB-W-01 에 KG\sys001 로 로그인 후 위와 같아야 한다.

▲ CB-W-02 에 KG\secu001 로 로그인 후 위와 같아야 한다.

3) RDP[3점]

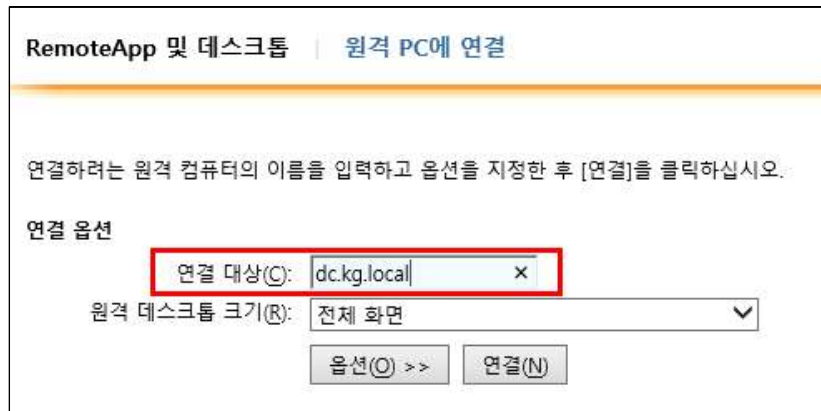
▲ 위 2) 채점에 이어서 CB-W-01 에 sys001 로 로그인 된 상태를 확인하다.

- IE를 실행시킨 후 즐겨찾기의 “ RD 웹 액세스” 를 실행 /

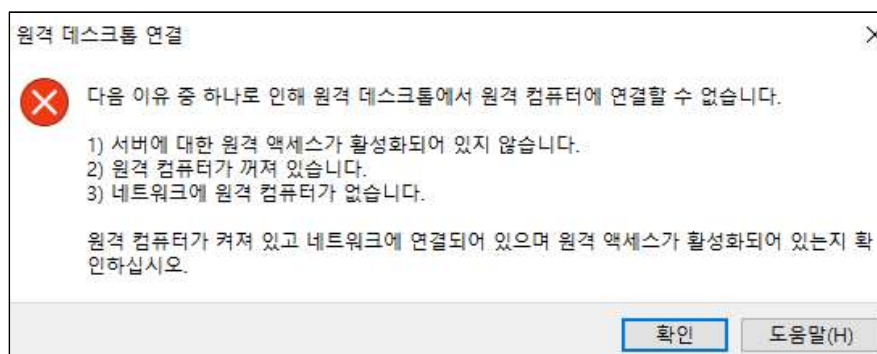
즐겨찾기가 없다면 <https://dc.kg.local/rdweb> 로 접속한다. 인증서 오류가 발생하지 않아야 채점을 진행한다. kg/remote (암호 cyberP@ss12#\$) 로 로그인



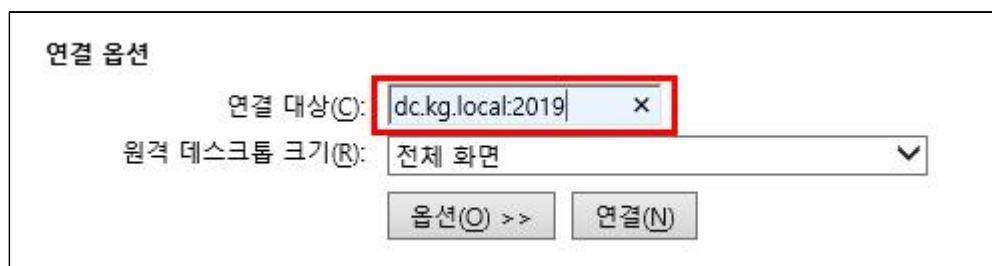
원격 PC에 연결 -> 연결대상 : dc.kg.local 입력 -> 연결



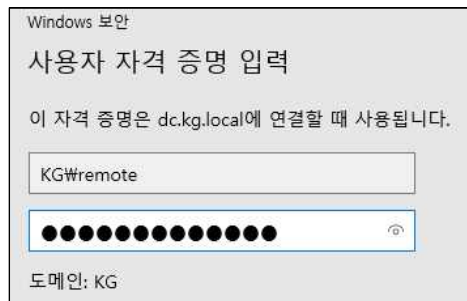
다음과 같이 오류가 발생해야 한다.



아래와 같이 dc.kg.local:2019 로 연결 시도



아래와 같이 로그인 창이 보이면서 KG\remote 로 연결이 성공해야 한다.

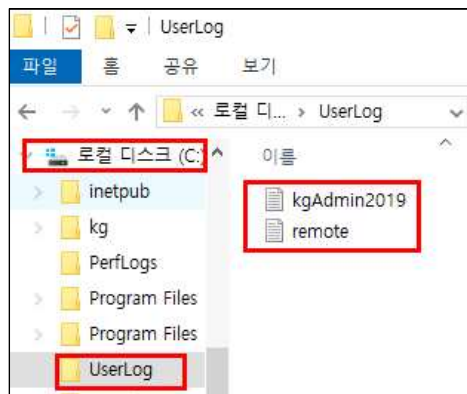


-> 접속 후 원격 접속 화면에서 컴퓨터를 종료한다.

-> 이때, 실제 컴퓨터가 아닌 원격 접속이 종료되는 것임.

4) DC 접속 로그[2점]

- DC 에 kgAdmin2019 로 로그인 -> 로그아웃 -> 다시 로그인 한다.
- 탐색기 ->



kgAdmin2019 파일을 연다.

형식이 아래와 같아야하고, 날짜와 시간이 채점 시 시스템 시간과 같아야 한다. (오차범위 5분 이내)

Login 2019-03-03,14:21:18.06,remote,DC
Logout,2019-03-03,14:34:01.76,remote,DC

remote 파일도 위와 같아야 한다.

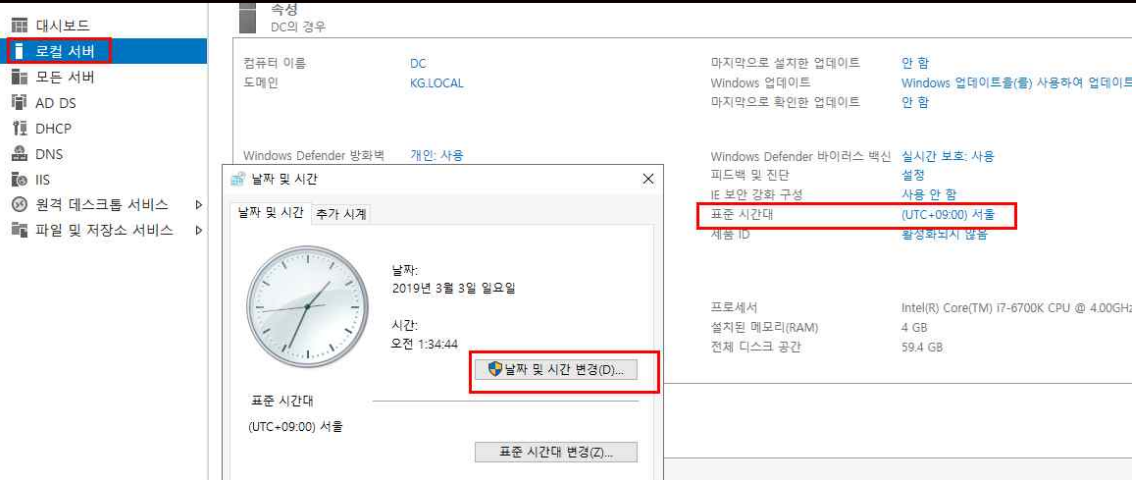
5) 암호정책[1점]

- DC에서 kgAdmin2019 로 로그인 후 파워셸에서 다음을 확인한다. [1점]

<대회장에서 공개>

6) 암호정책[1점]

- CB-W-02에서 web001 로 로그인 3회 실패를 한 후, 4회 로그인 시도 시 계정이 잠겼는지 확인한다.
- DC 서버의 시간을 1시간 후로 변경한다.

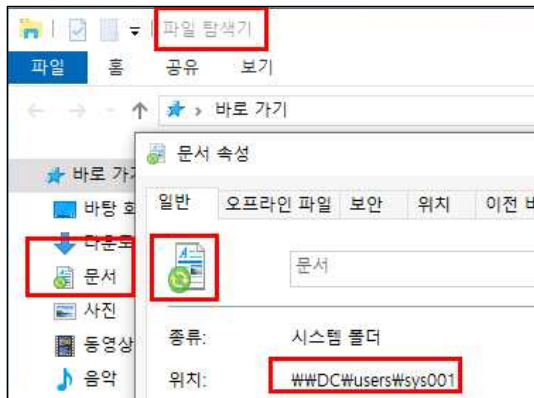


- CB-W-02에서 web001 로 (정상 암호 입력 cyberP@ss12#\$) 로그인에 성공해야 한다.

7) 폴더 리디렉션[2점]

▲ CB-W-01, CB-W-02 에 로그인된 모든 사용자를 로그아웃한다.

▲ CB-W-01 에 sys001 사용자로 로그인 한다.



로그아웃 후 secu001 로 로그인 한다.

왼쪽처럼 문서에 동기화 표시가 있어야 하고, 위치가 \DC\users\secu001 이 어야 한다.

로그아웃 후 web001 로 로그인 한다.

왼쪽처럼 문서에 동기화 표시가 있어야 하고, 위치가 \DC\users\web001 이 어야 한다.

● 응용프로그램 보안

1) ssh 인증키 설정

▲ CB-W-02 컴퓨터에 KG\secu001 에 로그인[2점]

바탕화면에 4개의 파일이 있는지 확인합니다. 파일명의 형식이 아래와 같이 일치되어야 하며, 101은 본인의 비번호이어야 합니다.

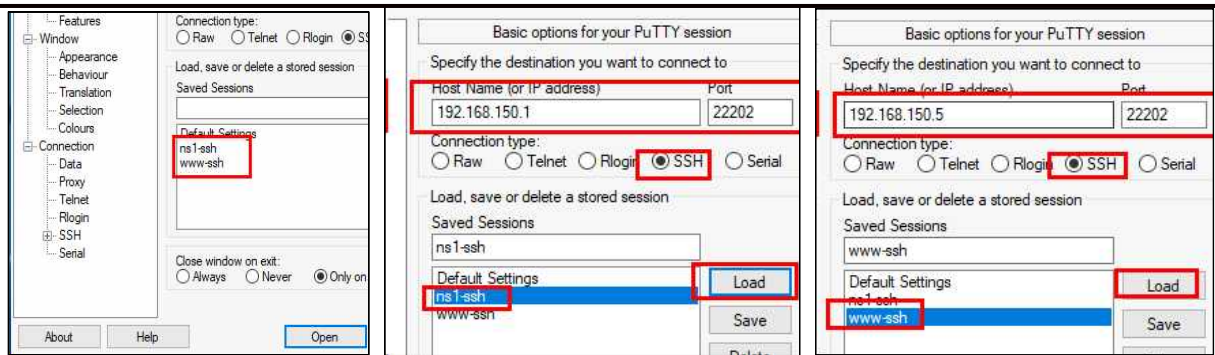


이어서 다음을 채점합니다.

2) putty 설정 및 접속[4점, 부분점수]

▲ putty 설정 : putty 를 실행한 후 다음과 같이 2개의 설정이 있는지 확인 [1점]

- 없다면 해당 항목은 0점 처리합니다.



▲ ns1-ssh 를 더블클릭하여 패스워드 입력 없이 접속되는지 확인합니다. [1.5점]

Using username "kgAdmin".

Authenticating with public key "imported-openssh-key"

Last login: <생략>

[kgAdmin@ns1 ~]\$

▲ www-ssh 를 더블클릭하여 패스워드 입력 없이 접속되는지 확인합니다.[1.5점]

Using username "kgAdmin".

Authenticating with public key "imported-openssh-key"

Last login: <생략>

[kgAdmin@www ~]\$

3) 웹서비스 인증[2점]

▲ www 서버에 secu2019 로 로그인 > root로 전환(su -)

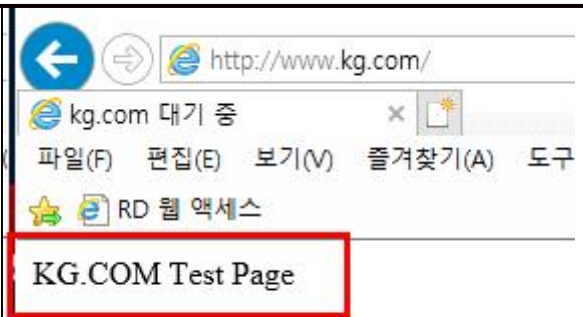
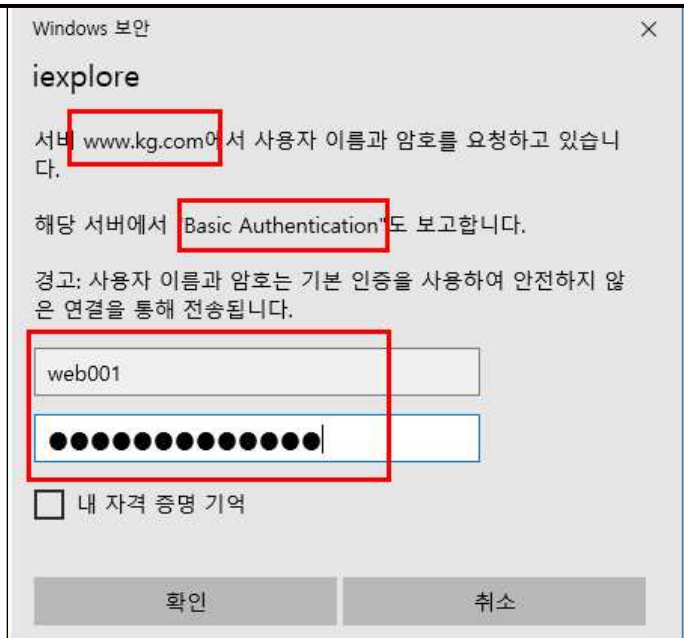
#echo "" > /var/log/httpd/kg.com/access.log

▲CB-W-01 에 web001 사용자로 로그인 > IE 를 실행 > <http://www.kg.com> 입력

아래와 같은 인증 메시지가 보이는지 확인

web001 ~ web005 사이의 사용자로 로그인한다. 암호 : cyberP@ss12#\$

홈페이지가 보여야 한다.



이어서 다음 4) 항목 확인

4) 웹서비스 인증[2점]

▲www 서버 에서 로그 확인

```
#cat /var/log/httpd/kg.com/access.log
```

로그가 다음과 같은 순서로 되어 있는지 확인한다.

시간 : IP : 로그인계정 : "URL" : 요청정보 : "브라우저정보" : 코드

```
[root@www conf]# cat /var/log/httpd/kg.com/access.log
[04/Mar/2019:06:25:07 -0500] : 172.30.20.150 : - : "www.kg.com" : GET / HTTP/1.1 : "Mozilla/5.0 (Windows NT 10.0; WOW64; Trident/7.0; rv:11.0) like Gecko" : 401
[04/Mar/2019:06:25:14 -0500] : 172.30.20.150 : web001 : "www.kg.com" : GET / HTTP/1.1 : "Mozilla/5.0 (Windows NT 10.0; WOW64; Trident/7.0; rv:11.0) like Gecko" : 200
[root@www conf]#
```

● 응용프로그램 보안

1) SW 설정 [4점, 부분점수]

▲ [1점] HOST-01 에서 CB-SW에 콘솔 접속한다.

- ciscoAdmin 으로 접속(암호 cyberP@ss12#\$) 시 프리빌리지드 모드로 접속되어야 한다.

```
Username: ciscoAdmin
Password:
CB-SW#
```

4 CB-SW# exit 입력 후 엔터를 입력한다.

아래와 같이 ciscoUser 접속한 후 User mode 로 접속되어야 한다.

```
Username: ciscoUser
Password:
CB-SW>
```

---> 여기까지 성공하면 1점

▲[2점] 인증 로그인

www 서버에 secu2019 로 접속 후 su - 를 입력하여 root 로 전환한다.
 # systemctl stop radiusd 인증서버 중지

<pre> CB-SW> exit Username: ciscoAdmin Password: % Authentication failed Username: ciscoUser Password: % Authentication failed Username: swAdmin Password: CB-SW# </pre>	CB-L-01 에 secu2019 로 접속한다. sw.kg.com 을 사용하지 못할 경우 172.30.30.100 을 사용해도 된다. \$ ssh -l ciscoAdmin sw.kg.com Password: <접속이 되지 않는다.> \$ssh -l swAdmin sw.kg.com Password: CB-SW# <-- 접속에 성공한다. CB-SW# exit
---	---

#systemctl start radiusd

CB-L-01 에서 다음과 같이 성공해야 한다.

```

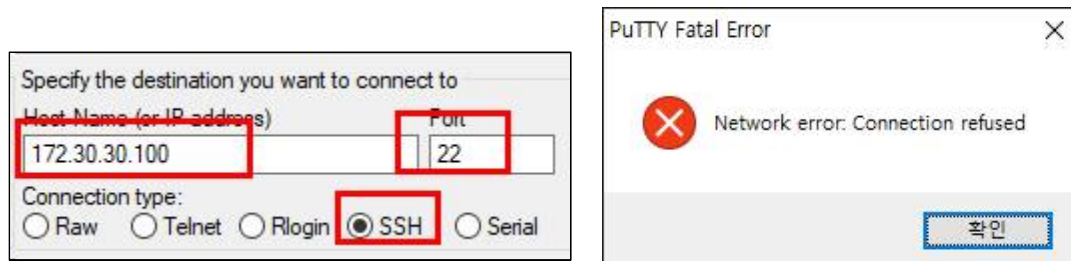
$ ssh -l ciscoUser 172.30.30.100
Password: 패스워드를 1번 이상 입력할 수도 있음
Password:
CB-SW> ena
Password:
CB-SW#

```

=> 2점

2) 네트워크 제한[1점]

▲ CB-W-01 에서 sys001로 로그인 > putty 실행 > 다음과 같이 거절되어야 한다.



3) UTM 설정

CB-W-02 에서 secu001 로 로그인 > IE 실행 > https://172.30.20.254 로 접속
 접속 계정 이름 : utmAdmin1 (암호 cyberP@ss12#\$)

<대회장에서 공개>

● 취약점 점검 보고서

1) IP 검색 결과[1점]

▲ attacker 에 root 로 로그인 합니다.

<대회장에서 공개>

2) 분석보고서[3점]

▲ 분석 보고서를 다음과 같이 작성합니다.

<대회장에서 공개>

5

3) 암호변경[3점]

▲ TestSRV tty1에 접속한다.

<대회장에서 공개>

4) 취약점해결[3점]

<대회장에서 공개>